

DQuez Carr

Module 2: Assignment

Web application technologies, identifying attack surfaces, and exploiting client-side controls

MCY 670 Web Security

Questions

1. (15 points) Discuss the different ways web applications can handle client-side data securely.

By reducing the quantity of private data transferred to or stored on the client, web applications may manage client side data safely. Because client side validation such as javascript checks can be readily circumvented, developers should make sure that any data received from the client is revalidated on the server side whenever client involvement is required. Secure protocols HTTPS should also be used while transmitting data in order to guard against tampering and interception. Sensitive information, including credentials and session tokens, is further protected by the use of encryption and hashing techniques.

Using situational verification such as one time passcodes to prevent replay attacks and impersonation is another aspect of safe client-side processing. To keep an eye on odd client behavior and facilitate quick attack response, developers should put in place appropriate logging and intrusion detection. Integrity and confidentiality in client server communication can be preserved by limiting the use of cookies, scripts, and hidden form fields for important data and making sure all user input is cleaned and verified.

2. (15 points) Why and how does intelligence gathering affect the outcomes of a successful and detailed security analysis for a client?

Because it determines what to test, how thoroughly, and where the actual threats reside, intelligence gathering influences the outcome of a security study. In order for testers to focus on high-impact targets rather than wasting time on low value checks, good reconnaissance (passive and active) reveals the client's assets, hosting, software versions, exposed services, and trust boundaries. Additionally, it makes ownership and scope (what is in and out of bounds) clear, avoiding operational or legal blunders and guaranteeing that the engagement is focused on systems that are important to the company.

The method used affects the quality of the results: realistic attack paths, plausible exploit attempts, and precise risk rating are made possible by comprehensive, context aware intelligence, which in turn results in remediation actions that are specific to the client's environment. On the other hand, inadequate or cursory reconnaissance results in inappropriate advice, false positives, or overlooked vulnerabilities. Last but not least, thorough collection enhances reporting and follow up (evidence, deadlines, reproducible actions), assisting stakeholders in accelerating remediation and tracking security advancements over time.